

Hippa Info

The HIPAA Privacy Rule establishes national standards for the protection of individuals' medical records and other individually identifiable health information. It sets clear boundaries on how this data can be handled by covered entities—such as healthcare providers, health plans, and clearinghouses—and their business associates.

Here is a detailed breakdown of the policy components that make up compliance:

Defining Protected Health Information (PHI)

Protected Health Information (PHI) includes any demographic information that can be used to identify a patient and relates to their past, present, or future physical or mental health condition, treatment, or payment.

To safely use health data for research or public health without violating privacy, the Department of Health and Human Services (HHS) requires the removal of **18 specific identifiers** to consider the data "de-identified":

1. **Names:** First, last, maiden, and nicknames.
2. **Geographic Data:** All subdivisions smaller than a state, including street address, city, county, precinct, and ZIP code.
3. **Dates:** All dates (except the year) directly related to the individual (birthdate, admission/discharge date, date of death), including exact ages for anyone 89 or older.
4. **Phone Numbers.**
5. **Fax Numbers.**
6. **Email Addresses.**
7. **Social Security Numbers.**
8. **Medical Record Numbers.**
9. **Health Plan Beneficiary Numbers.**
10. **Account Numbers.**
11. **Certificate or License Numbers** (e.g., driver's license).
12. **Vehicle Identifiers:** License plates or VINs.
13. **Device Identifiers and Serial Numbers.**
14. **URLs (Web Universal Resource Locators).**
15. **IP Addresses.**
16. **Biometric Identifiers:** Fingerprints, retinal scans, or voiceprints.
17. **Full-Face Photographs** or comparable images.
18. **Any other unique identifying number, characteristic, or code.**

The Minimum Necessary Standard

The Minimum Necessary Standard dictates that covered entities must make reasonable efforts to limit the access, use, and disclosure of PHI to only the information strictly required to accomplish the intended purpose.

- **Role-Based Access:** An employee should only have access to the specific data required to perform their job duties. For example, a medical coder needs diagnostic information to process a claim but does not need access to a patient's psychotherapy notes, while an IT technician maintaining a server does not need to view patient medical records at all.

- **Routine Disclosures:** Entities must establish policies that dictate exactly what information is shared for routine, recurring administrative requests.
- **Exceptions:** This standard does *not* apply when a healthcare provider requests full medical records for treatment purposes, when the patient explicitly authorizes a disclosure, or when information is required by law (such as an HHS compliance audit).

Patient Rights

The Privacy Rule grants patients significant control over their health data. Facilities must outline these rights clearly in a Notice of Privacy Practices (NPP) provided to the patient upon intake.

Key patient rights under the Privacy Rule include:

- **Right to Access:** Patients have the right to inspect and obtain a copy of their PHI. Providers must respond to these requests within 30 days and provide the data in the format requested by the patient (including electronic formats) if it is readily producible.
- **Right to Amend:** If a patient believes their health record is inaccurate or incomplete, they can formally request an amendment. If the provider denies the amendment, they must allow the patient to add a statement of disagreement to their record.
- **Right to Request Restrictions:** Patients can request limits on how their PHI is used or disclosed for standard operations. While providers aren't strictly required to agree to all requests, they *must* honor the restriction if a patient pays for a service entirely out-of-pocket and requests that the specific service data not be shared with their health insurance plan.
- **Right to an Accounting of Disclosures:** Patients can request a log of instances where their PHI was disclosed by the covered entity for reasons other than standard treatment, payment, or healthcare operations.

Permissible vs. Impermissible Disclosures

A core function of the Privacy Rule is defining exactly when PHI can and cannot be legally shared without a patient's direct authorization.

Permissible Disclosures

These are scenarios where a covered entity is allowed to use or share PHI without obtaining written authorization from the patient:

- **TPO (Treatment, Payment, Healthcare Operations):** Sharing data with another physician for a medical referral, sending a claim to an insurance company, or using data for internal quality assessments.
- **To the Individual:** Providing records directly to the patient or their legally authorized representative.
- **Public Interest and Benefit:** Reporting certain contagious diseases to public health departments, reporting suspected cases of abuse or neglect, complying with court orders, or providing necessary data to law enforcement under specific parameters.
- **Incidental Disclosures:** Minor, unavoidable disclosures—such as a patient's name being faintly overheard in a hospital hallway—are permitted, provided the facility has enacted reasonable administrative and physical safeguards to prevent them.

Impermissible Disclosures (HIPAA Violations)

An impermissible disclosure occurs when PHI is accessed, used, or shared without authorization and does not fall under an explicit regulatory exception. Common examples include:

- Employees snooping into the medical records of friends, family, coworkers, or celebrities without a job-related need.
- Selling PHI to third-party marketers without explicit written authorization from the patient.
- Losing unencrypted devices (like a laptop or USB drive) or paper files containing PHI.
- Discussing patient details in public areas where unauthorized individuals can clearly overhear the conversation.

The HIPAA Security Rule specifically governs **electronic Protected Health Information (ePHI)**. While the Privacy Rule dictates *who* can access data, the Security Rule dictates *how* that data must be protected. It requires covered entities and business associates to implement administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and availability of ePHI.

Here is a detailed breakdown of the policy components required to secure ePHI:

Password Hygiene and Multi-Factor Authentication (MFA)

Under the Security Rule's technical safeguards, organizations must implement strict access controls to verify that a person seeking access to ePHI is exactly who they claim to be.

- **Password Hygiene:** Compliance policies must enforce strong password requirements. This typically includes a minimum character length, a mix of uppercase and lowercase letters, numbers, and special characters. Policies should explicitly forbid the sharing of credentials between employees and require routine password resets (e.g., every 60 to 90 days) or immediately upon suspected compromise.
- **Multi-Factor Authentication (MFA):** Relying on passwords alone is no longer considered a sufficient safeguard for remote access or privileged accounts. Compliance requires MFA, meaning users must provide two or more verification factors to gain access. These factors include something you *know* (a password), something you *have* (a physical security token or a code sent to a mobile device), or something you *are* (biometrics like a fingerprint).
- **Unique User Identification:** Every employee must be assigned a unique name or number for tracking identity. This ensures that any access, modification, or deletion of ePHI can be audited and traced back to a specific individual.

Phishing Awareness and Recognizing Social Engineering Attacks

The Security Rule's administrative safeguards mandate that organizations implement a comprehensive security awareness and training program for all workforce members, including management. Technology alone cannot prevent breaches if the human element is compromised.

- **Mandatory Training:** Employees must undergo regular, documented training on how to identify cyber threats. This includes recognizing phishing emails (e.g., spoofed sender addresses, urgent demands for action, grammatical errors) and malicious links.
- **Social Engineering Defenses:** Staff must be trained to recognize pretexting and other social engineering tactics, such as an attacker calling the front desk pretending to be IT support to steal login credentials or a vendor requesting unauthorized access to a physical server room.
- **Reporting Protocols:** Compliance requires clear, non-punitive internal protocols for employees to report suspected security incidents. Staff must know exactly who to contact if they click a suspicious link or receive a questionable request for patient data.

Proper Use of Workstations, Mobile Devices, and Logging Off

Physical safeguards are required to protect electronic information systems and related buildings and equipment from natural and environmental hazards, as well as unauthorized intrusion.

- **Workstation Security:** Policies must govern the physical surroundings of computers accessing ePHI. This includes positioning monitors away from public view, utilizing privacy screens in high-traffic areas, and restricting the installation of unauthorized software.
- **Mobile Device Management (MDM):** Because mobile devices (laptops, tablets, smartphones) are highly susceptible to theft, compliance requires strict controls. If an organization allows Bring Your Own Device (BYOD), there must be policies enforcing security software. Organizations should use MDM tools to remotely track, lock, or wipe devices if they are lost or stolen.
- **Automatic and Manual Logoff:** To prevent unauthorized users from accessing an unattended computer, policies must mandate automatic session timeouts (e.g., the system locks after 5 to 10 minutes of inactivity). Additionally, workforce members must be trained to manually lock their screens every time they step away from their desks.

Encryption and Secure Transmission of ePHI

Transmission security requires organizations to guard against unauthorized access to ePHI that is being transmitted over an electronic communications network, as well as protecting it while it is stored.

- **Encryption at Rest:** This involves securing data stored on hard drives, databases, laptops, and flash drives. If an encrypted device is lost or stolen, the data remains unreadable to anyone without the decryption key. Crucially, under the HIPAA Breach Notification Rule, if a device is lost but the ePHI on it was properly encrypted according to NIST standards, it is treated as a "safe harbor" and does not constitute a reportable data breach.
- **Encryption in Transit:** Whenever ePHI is sent outside the internal secure network, it must be encrypted. This means using secure file transfer protocols (SFTP), enforcing HTTPS/TLS for web portals, and utilizing specialized secure email services. Sending unencrypted ePHI via standard email or text message is a direct violation of the Security Rule.

- **Integrity Controls:** Organizations must implement policies and procedures to corroborate that ePHI has not been altered or destroyed in an unauthorized manner during transmission. This is often achieved through digital signatures or checksums.

The HIPAA Breach Notification Rule mandates the process that covered entities and their business associates must follow if Protected Health Information (PHI) is compromised. It establishes strict guidelines on how to assess an incident, who must be informed, and the required timeline for reporting.

Here is a detailed breakdown of the policy components regarding incident reporting:

Reportable Breach vs. Non-Reportable Security Incident

Not every security event triggers a public breach notification. Compliance requires a clear understanding of the distinction between an incident and a reportable breach.

- **Security Incident:** The HIPAA Security Rule defines an incident as the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations. For example, a firewall blocking an attempted cyberattack or a brief network outage are security incidents, but they do not necessarily mean PHI was compromised.
- **Reportable Breach:** A breach is defined as an impermissible use or disclosure under the Privacy Rule that compromises the security or privacy of PHI.

The Risk Assessment Test

When an impermissible disclosure occurs, the law presumes a reportable breach has taken place *unless* the organization can demonstrate a low probability that the PHI was actually compromised. To prove it is non-reportable, the entity must conduct a four-factor risk assessment:

1. **The nature and extent of the PHI involved:** Was it highly sensitive data (like mental health records or Social Security numbers) or just a list of appointment times?
2. **The unauthorized person who accessed or received it:** Did the data go to a trusted entity (like another physician who is also bound by HIPAA) or an unknown cybercriminal?
3. **Whether the PHI was actually acquired or viewed:** Was a stolen laptop recovered before anyone logged in?
4. **The extent to which the risk has been mitigated:** Was a misdirected email successfully recalled and deleted by the recipient before it could be read or forwarded?

The Safe Harbor Exception: As established by the Security Rule, if the compromised data was encrypted according to National Institute of Standards and Technology (NIST) guidelines, and the decryption key was not compromised, the event is legally considered a non-reportable security incident, not a breach.

Examples of Common Breaches

Organizations must have policies identifying common scenarios that constitute a breach so that staff know when to trigger the incident response plan.

- **A Lost or Stolen Clinic Laptop:** If an unencrypted mobile device or hard drive containing PHI is left in a vehicle, misplaced in an airport, or stolen from an office, it is an automatic breach. The organization has no way to prove the data was not viewed or extracted.
- **A Misdirected Fax or Email:** Sending a patient's lab results to the wrong fax number, attaching the wrong medical file to a patient portal message, or using "CC" instead of "BCC" on a mass email to patients. If the recipient is an unauthorized third party, it is a breach.
- **Unauthorized Access (Internal or External):**
 - *Internal:* A workforce member snooping through the records of a neighbor, ex-spouse, or local celebrity without a valid medical reason.
 - *External:* A hacker successfully deploying a phishing attack that yields an employee's credentials, allowing the attacker to download databases or deploy ransomware that locks down the EHR (Electronic Health Record) system.

The 60-Day Breach Notification Rule

When a reportable breach is identified, compliance requires strict adherence to notification timelines and protocols.

- **The 60-Day Deadline:** Organizations must notify affected individuals "without unreasonable delay," and absolutely no later than **60 calendar days** from the *discovery* of the breach. The "date of discovery" is the day the breach is known, or the day it *should have been known* if the entity was exercising reasonable diligence.
- **Required Notification Contents:** The letters sent to affected patients via first-class mail must contain specific information, including:
 - A brief description of what happened, including the dates of the breach and its discovery.
 - The exact types of unsecured PHI that were involved (e.g., names, dates of birth, diagnoses).
 - The steps individuals should take to protect themselves (e.g., monitoring credit reports).
 - A brief explanation of what the organization is doing to investigate, mitigate harm, and prevent future occurrences.
 - Toll-free contact information for individuals to ask questions.

Scaling Notifications Based on Size

The requirements for notifying external authorities scale based on the number of individuals affected:

- **Fewer than 500 individuals:** The organization must notify the affected individuals within 60 days. They must also notify the Secretary of the Department of Health and Human Services (HHS), but this can be done annually (within 60 days of the end of the calendar year in which the breach occurred).

- **500 or more individuals:** The organization must notify the affected individuals, the Secretary of HHS, and prominent local media outlets (issuing a press release) in the jurisdiction where the affected individuals reside—all within the 60-day window.

When applying HIPAA regulations specifically to a Federally Qualified Health Center (FQHC), the policies must be translated into concrete, daily workflows for your clinic's staff. It is not enough to know the law exists; employees must know exactly who is in charge and what steps to take when issues arise.

Here is a detailed breakdown of how these specific requirements should be structured within an FQHC compliance policy:

Designated Privacy and Security Officers

The HIPAA Security Rule mandates that every covered entity, regardless of size, must formally designate individuals to oversee compliance. In an FQHC, these roles are the linchpins of the privacy program.

- **The HIPAA Privacy Officer:** This individual is primarily responsible for the "human element" and administrative policies of HIPAA. Their duties include developing and updating the clinic's Notice of Privacy Practices (NPP), managing Business Associate Agreements (BAAs), overseeing workforce privacy training, and establishing the processes for handling patient records requests and privacy complaints.
- **The HIPAA Security Officer:** This individual is focused on protecting Electronic Protected Health Information (ePHI) and the technology systems that house it. Their duties include conducting regular security risk analyses, implementing technical safeguards (like access controls, encryption, and audit logs), developing disaster recovery plans, and overseeing the response to potential cyber threats.

Note: In larger health systems, these are often two distinct roles. However, in smaller FQHCs, it is common for a single individual (such as a Compliance Manager or IT Director) to serve as both the Privacy and Security Officer, often referred to generally as the HIPAA Compliance Officer. The clinic's policy must explicitly state the names, titles, and contact information for the individuals currently holding these roles.

Internal Breach Reporting Procedures

A critical component of an FQHC's policy is ensuring that every employee—whether a physician, front desk receptionist, or billing specialist—knows exactly how to report a suspected breach.

If an employee suspects a violation (e.g., they find an unencrypted laptop missing, they witness a coworker snooping in a chart, or they realize they faxed a referral to the wrong number), the policy should dictate the following steps:

1. **Immediate Internal Reporting:** Employees should be instructed to report the incident immediately. The policy must define the designated channels for this, which typically

include reporting to their direct supervisor, using a confidential internal compliance hotline, or contacting the Privacy Officer directly.

2. **Required Documentation:** The employee should provide a clear, factual account of the incident. This includes *who* was involved, *what* happened, *when* and *where* it occurred, and *how* the PHI was affected. Employees must be trained to include only the minimum necessary information to describe the issue and to avoid attaching full medical records or unnecessary PHI to their internal report.
3. **Preserve Evidence:** Employees should be instructed not to attempt to "fix" the issue by deleting messages or altering records, as this can impede the internal investigation. They should also avoid confronting the suspected individual directly.
4. **Internal Investigation:** Once reported, the Privacy or Security Officer (or a designated incident response team) must conduct a formal risk assessment to determine the severity of the violation and whether it constitutes a reportable breach under HHS guidelines.

Crucially, the policy must also inform employees of their right to escalate the complaint directly to the HHS Office for Civil Rights (OCR) if they feel the clinic failed to act on their internal report, or if they fear retaliation.

Handling Patient Requests and Complaints

An FQHC must have clear, documented procedures for responding to patients who exercise their rights under the Privacy Rule.

Patient Record Requests

When a patient requests access to their medical records:

- The clinic must have a standardized process (and often a specific form) for receiving these requests.
- The policy must enforce the 30-day deadline required by HIPAA to provide the records.
- Staff must know how to provide the records in the format requested by the patient (e.g., printed copies, a secure digital portal, or an encrypted email) if it is readily producible.

Patient Privacy Complaints

Patients have the right to file a formal complaint if they believe their privacy rights have been violated.

- The clinic's Notice of Privacy Practices (NPP) must clearly state how a patient can file an internal complaint, providing the direct contact information for the clinic's Privacy Officer.
- The Privacy Officer is responsible for logging, tracking, and investigating every patient complaint received.
- The policy must explicitly state that the FQHC will not retaliate against any patient for filing a complaint, whether that complaint is filed internally with the clinic or externally with the OCR.

In the eyes of the Department of Health and Human Services (HHS) Office for Civil Rights (OCR)—the enforcement agency for HIPAA—if it isn't documented, it didn't happen. During an audit or a breach investigation, providing a well-written policy is not enough. You must produce the hard evidentiary trail proving that your clinic actually executed on that policy and trained its workforce.

Here is a detailed breakdown of the compliance rules that govern training documentation and retention:

The Six-Year Retention Rule

Under HIPAA Administrative Simplification standards (**45 CFR § 164.530(j)(2)** and **45 CFR § 164.316(b)(2)**), covered entities must retain all privacy and security documentation for a minimum of **six years**.

- **The Clock Starts Later:** The six-year period runs from the date the document was *created* or the date it *last was in effect*, whichever is later. For example, if you create an employee training policy in 2026 and retire that policy in 2028, you must retain the policy and all training logs associated with it until at least 2034.
- **What Must Be Retained:** You are required to hold onto your written training policies, the training curriculum/slide decks themselves, and the complete audit trail of every individual employee's completion records.

Required Data Elements per Employee Record

To withstand an OCR audit, your clinic's training logs must capture specific, granular data points for every single member of your workforce (including full-time staff, part-time employees, volunteers, trainees, and students).

Data Element	Policy Requirement & Audit Purpose
1. Name and Role	Proves <i>who</i> was trained. Including the job title/role is vital because HIPAA requires role-based training —a medical records clerk should receive different, more specific instruction than a facilities maintenance technician.
2. Date Completed	Proves <i>when</i> the training occurred. HIPAA requires training "within a reasonable period of time after [the person] joins the workforce" (typically enforced as within 30 days of hire) and periodically thereafter (industry standard is annually).

3. Module Name / Curriculum	Proves <i>what</i> they learned. The log must tie back to the specific version of the training material. During an audit, investigators will ask for the training deck to verify that it covered required topics (e.g., FQHC workflows, phishing, PHI definitions).
4. Test Score / Assessment	Proves comprehension . While HIPAA does not explicitly mandate a formal quiz, best-practice compliance policies require a minimum passing score (usually 80% or higher) to prove the employee didn't just passively click through the slides without understanding the rules.
5. Signature / Attestation	Proves accountability . A legally binding attestation (physical or an electronic signature with a date/time stamp) where the employee certifies: <i>"I have completed this training, I understand my obligations under the clinic's HIPAA policies, and I agree to abide by them."</i>

Technical vs. Administrative Execution

How your clinic actually tracks this documentation determines your level of audit readiness:

- **Learning Management Systems (LMS):** Best practice for FQHCs is to utilize an electronic LMS or compliance software (e.g., Healthicity, Meditrain, or an HR portal). An LMS automatically records IP addresses, time spent on modules, test scores, and generates unalterable time-stamped electronic signatures.
- **Manual Log Tracking:** If your clinic conducts live, in-person training or uses a paper system, you must use a standardized **Training Attendance Sign-In Sheet**. This physical document must contain the printed name, signature, role, and date for every attendee, attached directly to a copy of the agenda and slide deck used on that day.

Tracking Triggered and Role-Change Training

Compliance policies must account for training execution outside of standard new-hire onboarding and annual refreshers:

- **Material Change Training:** Under **45 CFR § 164.530(b)(2)**, if your clinic makes a material change to its privacy or security policies (e.g., rolling out a new Electronic Health Record system or updating your PHI transmission rules), you must provide targeted training on that change to affected staff **within a reasonable timeframe**, and log that completion separately.
- **Remedial / Retraining Logs:** If an employee causes a security incident (such as clicking a phishing link or misdirecting a fax), compliance policies should mandate

remedial training. Your documentation must track that the specific employee completed corrective retraining following the incident.

An Operational Site Visit (OSV) is conducted by the Health Resources and Services Administration (HRSA) to evaluate a Federally Qualified Health Center's (FQHC) compliance with the statutory and regulatory requirements of the Health Center Program. These visits provide a comprehensive organizational assessment of the health center's clinical, fiscal, and administrative/governance operations.

Notification and Timing

An OSV is **not impromptu**. Health centers are notified in advance and coordinate the scheduling of the visit.

- **General Timing:** For health centers with a 3-year period of performance, OSVs typically occur around the mid-point of the period (approximately 12 to 16 months into the project period).
- **Exceptions:** HRSA retains the right to conduct an unannounced or emergent site visit at any time if there is an immediate need, such as a patient safety concern.
- **Pre-Visit Planning:** FQHCs are expected to prepare for the visit ahead of time, which includes a pre-site visit call with the HRSA staff and consultant reviewers to coordinate logistics and clarify responsibilities. Health centers must also submit required documents, often utilizing specific file-naming conventions, at least two weeks before the visit.

The OSV Process

The typical OSV lasts about 2.5 to 3 days on-site and is conducted by a site visit team composed of a HRSA representative and consultant reviewers. The process generally follows these steps:

1. **Pre-Site Document Review:** The site visit team reviews policies, procedures, and data submitted by the health center before arriving.
2. **Entrance Conference:** The visit begins with an introductory meeting.
3. **On-Site Assessments:** The team conducts a thorough review that includes:
 - **Document Reviews:** Verifying compliance through clinical records, financial data, and administrative policies.
 - **Interviews:** Meeting with key staff, management, and the health center's governing board. The board meeting must involve the board members alone (without staff) and can be held via phone or video conference.
 - **Facility Tours:** Physically inspecting the site to verify operations and standards.
4. **Exit Conference:** The visit concludes with a meeting to discuss preliminary findings.

Post-Visit Reporting

Within 45 days following the visit, HRSA provides the health center with a final site visit report. This report outlines the compliance determinations. If the health center fails to demonstrate

compliance in any area, HRSA will place conditions on its award, and the center must resolve the non-compliance findings.

Preparing for a Health Resources and Services Administration (HRSA) Operational Site Visit (OSV) requires managing a massive amount of documentation. The documents you need to produce are dictated by the **Operational Site Visit Required Documents and File Naming Convention checklist**, which directly aligns with the chapters of the Health Center Program Compliance Manual.

Here is a highly detailed breakdown of the documents evaluated during the OSV process, organized by the stages of preparation and the operational areas they cover.

Phase 1: Pre-Visit (Documents HRSA Already Has)

Before the site visit team even asks your FQHC for files, HRSA provides the reviewers with a foundational packet of your existing documentation. You do not need to upload these, but your internal team must review them to ensure everything you *do* submit aligns with what HRSA has on record:

- Your current Service Area Competition (SAC), New Access Point (NAP), or Renewal of Designation (RD) applications.
- Your most recent Budget Period Progress Report (BPR) or Annual Certification (AC) Report.
- **Form 5A (Services Provided)** and **Form 5B (Service Sites)**.
- The report from your most recent OSV (to check for historical context and resolved issues).
- Uniform Data System (UDS) Reports, including the Summary, Trend, and Performance Comparison reports.
- A list of any current progressive action conditions or supplemental awards your health center has.

Phase 2: Health Center Internal Preparation Timeline

Because of the sheer volume of documentation, FQHCs typically stage their document gathering over a 12-month period.

6 to 12 Months Before the Visit

At this stage, you are looking for structural documents and identifying gaps:

- Updated organizational Policies and Procedures.
- Results from internal mock audits.
- The current HRSA Compliance Manual requirements to cross-reference with your active policies.

3 to 6 Months Before the Visit

This stage focuses on validating files and records:

- **Board Compliance:** Validation of board demographic representation and voting eligibility.
- **Clinical Files:** Preliminary patient chart audits and verification of credentialing files.
- **Financial Documents:** A review of your Sliding Fee Discount Program (SFDP) documentation.

1 to 3 Months Before the Visit

This is the final packaging stage:

- Finalized electronic files organized and named precisely according to HRSA's naming conventions (e.g., categorizing them strictly by Chapter).
- Quality Improvement (QI) data.
- Staff training records.

Phase 3: The Core Document Submission (By Category)

Two to four weeks prior to the visit, you will submit a heavily structured digital binder. Reviewers will look for specific elements within these documents across four primary categories.

1. Governance and Administration (Chapters 17 & 18)

HRSA reviewers heavily scrutinize board oversight. You must provide:

- **Board Meeting Minutes:** Minutes must explicitly document quorum verification, budget approvals, the CEO's performance evaluation, reviews of clinical quality, oversight of the sliding fee program, and strategic discussions.
- **Board Composition Records:** Patient status documentation of board members, demographic representation data, voting eligibility records, and board attendance records.
- **Contracts (Chapter 10):** A complete list of all active contracts (and those ending less than 3 years ago) supporting the HRSA-approved scope of project. For federally supported contracts, you must include the procurement procedures (solicitation of bids, cost analysis, selection rationale, and the final contract with pricing terms).

2. Clinical Operations and Quality (Chapters 3, 6, & 8)

Clinical services are one of the most heavily audited components. Be prepared to provide:

- **Provider Credentialing Files:** Licenses, DEA registrations, board certifications, National Practitioner Data Bank (NPDB) queries, background checks, immunization records, and privileging approvals. *Note: Reviewers will check that providers are re-credentialed every two years.*
- **Patient Record Audits:** Reviewers will pull patient records looking for documentation completeness, signed provider notes, medication reconciliation, follow-up tracking, care coordination, and referral documentation.
- **Quality Data:** Extraction methodologies for clinical data, preventive care measures, chronic disease management metrics, and patient outcome monitoring.

3. Human Resources and Compliance (Chapters 9, 11)

You must prove your staff is qualified and properly trained:

- **Personnel Files:** Job descriptions, licenses/certifications, competency evaluations, and background checks.
- **Training Records:** Documented staff education related to HIPAA, OSHA, infection prevention, emergency preparedness, compliance, and cultural competency.

4. Risk Management and Facility Safety (Chapter 4)

You must demonstrate a safe environment and secure data:

- **Incident Reports:** Documentation showing that incident reports are completed consistently, investigated promptly, and that corrective actions and trends are monitored.
- **Risk Management Activities:** Risk assessments, safety initiatives, infection prevention monitoring (surveillance logs, PPE protocols, sterilization processes), and patient safety reviews.
- **Emergency Preparedness Plans:** Programs addressing natural disasters, power outages, infectious disease outbreaks, and cybersecurity incidents. You must also supply logs of fire drills and tabletop exercises.
- **Cybersecurity & IT:** Documentation of HIPAA safeguards, access controls, backup systems, incident response plans, user access reviews, and evidence that password protocols are enforced.